Smiles S.A.

RELATÓRIO DE AUDITORIA
N°. 2016-1/3432

Assunto: AIC - COBIT - S.DS5.9.A - Administrar Patches

Período da Auditoria:
01/08/2016 a 06/09/2016

Smiles S.A.

ÍNDICE

1 INTRODUÇÃO 3
2 OBJETIVO 3
3 ESCOPO 3
4 CONCLUSÃO 3
5 DETALHAMENTO DE RISCOS E CONTROLES 3
5.1 SDS5.9A.R01.SDS5.9A.C01 3
5.1.1 SDS5.9.A.C01 3
5.2 SDS5.9A.R01.SDS5.9A.C02 4
5.2.1 SDS5.9.A.C02 4
5.3 SDS5.9A.R02.SDS5.9A.C03 5
5.3.1 SDS5.9.A.C03 5

Smiles S.A.

1 INTRODUÇÃO

Auditoria no processo S.DS5.9.A - Administrar Patches

2 OBJETIVO

Nosso trabalho teve como objetivo a verificação quanto à efetividade dos controles do Processo do Cobit - Administrar Patches para mitigar os riscos vinculados com as atividades desse Processo, no contexto da avaliação da Administração (testes da Administração) para certificação 404-SOX.

3 ESCOPO

Verificar se a aplicação de patches foi efetuada para os servidores e estações de trabalho.

4 CONCLUSÃO

Os controles testados, definidos na Matriz de Riscos e Controles, não estão sendo executados de forma efetiva. Nossos testes revelaram pontos e deficiências relevantes que colocam em risco o ambiente de controles gerais da área de TI, tais como:

. Não existe um acompanhamento formal por parte da área de TI da Smiles sobre as Patches aplicadas ou não aplicadas nas estações de trabalho e servidores da Smiles S/A.

. Não foi definido nenhum controle com o objetivo de identificar, entre todas as Patches disponibilizadas pelos fabricantes, quais são críticas e elegíveis para o ambiente da Smiles S/A.

. O controle sobre a coleta e a divulgação dos indicadores deste processo não está sendo executado.

5 DETALHAMENTO DE RISCOS E CONTROLES

5.1 SDS5.9A.R01.SDS5.9A.C01

Descrição Risco:	Exposição de dados sensíveis e violações de requisitos legais e regulatórios, sistemas e dados propenso a taques de vírus e contra medidas inefetivas.

5.1.1 SDS5.9.A.C01

Descrição Controle:	As aplicações de Patches serão feitas através de mudanças autorizadas seguindo o processo de gestão de Mudanças.
Efetividade:	Efetivo

Ponto:

PA-01 Não consta no procedimento e matriz de risco deste processo de quem é a responsabilidade pela identificação e aplicação de Patch nas estações de trabalho e servidores (Servidores Smiles e Servidores compartilhados entre Gol e Smiles).

Recomendação:

PA-01 Definir os responsáveis (área de TI da Smiles e/ou da VRG) pela aplicação e acompanhamento das patches aplicadas nas estações de trabalho e servidores.

5.2 SDS5.9A.R01.SDS5.9A.C02

Descrição Risco:	Exposição de dados sensíveis e violações de requisitos legais e regulatórios, sistemas e dados propenso a taques de vírus e contra medidas inefetivas.

5.2.1 SDS5.9.A.C02

Descrição Controle:	Validação da aplicação de patches em servidores e estações de trabalho através das evidências fornecidas pelos fornecedores que gerenciam os ambientes impactados (TIVIT, ORACLE e AWS).
Efetividade:	Inefetivo

Ponto:

NCONF-01 Verificamos que as áreas de Segurança da Informação e Infraestrutura da Smiles não realizam nenhum acompanhamento sobre a aplicação de patches nas estações de trabalho visando identificar alguma falha no processo de atualização. Adicionalmente identificamos que das 11 (onze) estações de trabalho selecionadas para nossas análises, 01 estação de trabalho não foi aplicada atualização de patch há mais de um ano. Conforme listada a seguir:

Patrimônio	Nome	Setor	Data da Verificação da Atualização	Data da Última Atualização Instalada	Resultado da análise
297	João Paulo Andrade	CRM	22/06/2016	10/06/2015	Estação de trabalho se encontra com patch desatualizada há mais de 1 ano.

Ressaltamos que conforme descrito no item "**6.1. Infraestrutura"** desse procedimento é responsabilidade da área de TI da Smiles: **"***Garantir que um número igual ou superior a 80% das estações de trabalho ativas na rede domínio SMILES estejam atualizadas com os patches considerados elegíveis".*

No entanto, a Gerência de Infraestrutura informou que não tem como garantir que 80% das máquinas estão com as atualizações de patches aplicadas, uma vez que não existe nenhum relatório de acompanhamento.

NCONF-02 Não foi definido neste procedimento nenhum controle com o objetivo de identificar entre todas as patches disponibilizadas pelo fabricante, quais são críticas (elegíveis) para o ambiente da Smiles e que dessa forma devem ser aplicadas nas estações de trabalho e servidores.

PA-02 Não consta no procedimento e matriz de risco deste processo um controle referente a aplicação de patch em ambiente de Homologação, antes de colocar em ambiente de Produção. Contemplando estações de trabalho e servidores.

PA-03 Verificamos que o controle S.DS5.9.A.C02 está definido como semestral. Entendemos que assim como a aplicação de patch é efetuada sob demanda (S.DS5.9.A.C01), esse controle deverá ser executado sob demanda também.

PA-04 A matriz de risco e o procedimento deste processo (Administração de Patches) estão resumidos de uma forma que dificulta o seu adequado entendimento, bem como não existe uma referência entre o procedimento e a matriz de risco.

Recomendação:

NCONF-01 Recomendamos que as áreas de Segurança da Informação e Infraestrutura Smiles tenham um controle mais efetivo em relação as atualizações de patches para estações de trabalho e servidores.

NCONF-02 Recomendamos que seja criado um controle que identifique quais patches são elegíveis para aplicação nos servidores e estações de trabalho.

PA-02 Recomendamos que sejam realizados testes das atualizações de patches em ambiente de homologação antes das mesmas serem aplicadas em ambiente de Produção.

PA-03 Recomendamos que o controle S.DS5.9.A.C02 tenha sua frequência de execução alterada de semestralmente para sob demanda.

PA-04 Recomendamos que esse procedimento seja aprimorado e descrito de uma forma mais detalhada, demonstrando como serão realizados os monitoramentos e acompanhamentos sobre atualização de patches para as estações de trabalho e servidores de que forma a área de TI da Smiles deverá atuar nesse processo.

5.3 SDS5.9A.R02.SDS5.9A.C03

Descrição Risco:	Não ocorrer a divulgação de indicadores do processo

5.3.1 SDS5.9.A.C03

Descrição Controle:	Quantidade de Pacths implementados.
Efetividade:	Inefetivo

Ponto:

NCONF-03 O controle sobre a coleta e divulgação de indicador não está sendo executado conforme definido na matriz de risco e procedimento deste processo. Adicionalmente

entendemos que o indicador deste processo não auxilia a área de Governança de TI na identificação de falhas / desvios no processo de Administração de Patch, sendo pouco efetivo como métrica para esse processo.

Recomendação:

NCONF-03 Recomendamos que o controle sobre a coleta e divulgação do indicador seja executado conforme definido na matriz de risco e procedimento deste processo. Sugerimos ainda que a área de TI crie novos indicadores que possam auxiliar de forma mais efetiva a área de TI na identificação de falhas / desvios no processo de Administração de Patch. A título de sugestão listamos os seguintes indicadores:

- Percentual de máquinas elegíveis que foram atualizadas no período
- Percentual de máquinas que estão ou não com patches aplicadas.

Smiles S.A.

Envolvidos na Auditoria:

_____
Delio Goldner
Revisor

_____
Marcio Mendes
Revisor

_____
Andre Luis Gonçalves Fernandes
Auditor Responsável

_____
Juliana Genio Dantonio
Aprovador 1a Alçada